Thor's Quick Sheets - CC® Domain 5

Contents

Configuration, Patch, and Change Management 2

Cryptography, Hashing, and Attacks on our Cryptography 2

Data Handling, Classification Labeling, Retention, Destruction/Disposal 3

Administrative (Directive) Controls 4

Training and Awareness 5

Social Engineering 5

Configuration, Patch, and Change Management

Configuration Management:

- Harden systems before integration into the environment.
- Use standard OS images for efficiency and consistency.
- Conduct vulnerability scans pre-introduction (critical for servers/network devices).
- **Practices:**
  - Close unnecessary ports, disable services, delete unused accounts, apply patches.
  - Maintain a baseline for system hardening.
  - Monitor deviations from the security baseline post-integration.

Patch Management: Regularly apply patches to maintain network security.

- **Practices:**
  - Patch systems after vulnerabilities are discovered and reviewed.
  - Include updates for network equipment, arrays, IoT devices.
  - Use software to uniformly distribute patches across systems.

Change Management: Manage changes with full documentation and communication.

- **Practices:**
  - Involve IT and operational units in a change review board.
  - Present the change, assess risks, and obtain approvals.
  - Follow a structured process: Identify, propose, assess, approve, test, schedule, notify, implement, and report.
  - Document the change process for audits and risk mitigation.

Cryptography, Hashing, and Attacks on our Cryptography

Cryptography

- **Confidentiality:** Keep secrets secret.
- **Integrity:** Ensure data remains unaltered.
- **Authentication:** Verify identities; can provide non-repudiation.

Cryptology: Science of securing communications.
Cryptography: Creating hidden messages.
Cryptanalysis: Breaking encrypted communication.
Cipher: Cryptographic algorithm.
Plaintext: Unencrypted message.
Ciphertext: Encrypted message.
Encryption: Converts plaintext to ciphertext.
Decryption: Converts ciphertext back to plaintext.
Historical Ciphers:

- **Spartan Scytale:** Message deciphered by wrapping parchment around a stick.
- **Caesar Cipher:** Substitution by shifting letters in the alphabet.
- **Book Cipher:** Uses a book as a key with coordinates (e.g., page, sentence, word).
- **Running-Key Cipher:** Uses a known text and phrase for encryption.

Encryption Types:

- **Asymmetric (Public Key Encryption):** Uses a public and private key pair.
  - Pros: No pre-shared key needed; scalable.
  - Cons: Slower, weaker per bit.
- **Symmetric:** Uses the same key for encryption and decryption.
  - Pros: Faster, stronger per bit.
  - Cons: Requires pre-shared key; complex with many users.
- **Hybrid:**
  - Combines asymmetric and symmetric encryption.
  - Uses asymmetric to share symmetric session keys, then symmetric for data transfer.

Hashing

- Hash functions create a fixed-length hash value from variable-length input.
- Used to ensure data integrity; even minor changes to data result in a completely different hash.

Key Concepts:

- **Integrity:** Verifies data has not been altered.
- **Collisions:** Occur when different data inputs produce the same hash; very unlikely.
- **Sensitivity:** Even a 1-bit change significantly alters the hash.

Example:

- Changing a small element (e.g., a comma or period) in a document drastically changes the hash output.

Attacks on our Cryptography

Steal the Key:

- Easier than breaking encryption; involves accessing the key directly from systems or repositories.
- Used by law enforcement with warrants and attackers via system breaches.

Brute Force:

- Attempts every possible key to decrypt data.
- Effective against key-based ciphers except for the one-time pad.

Key Stretching: Delays password verification to hinder brute force attempts.

Man-in-the-Middle Attack (MITM):

- Attacker intercepts and possibly alters communication between two parties.
- Requires access to the communication channel.

Side Channel Attacks: Exploits physical data (e.g., CPU cycles, power usage) to break encryption.

Data Handling, Classification Labeling, Retention, Destruction/Disposal

Sensitive Information Management:

- **Data Handling:** Only trusted individuals should manage data. Implement policies and logging for tracking data handling activities.
- **Data Storage:** Store securely in climate-controlled, geographically safe facilities. Avoid insecure practices like unmonitored tape backups.

- **Data Retention:**
  - Retain data only as long as necessary for usefulness or legal requirements.
  - Regulations (e.g., HIPAA, PCI-DSS) dictate retention periods; ensure compliance.

Data Disposal:

- **Paper Disposal:** Use secure methods like cross-shredding to prevent reconstruction.

Digital Disposal:

- **Soft Destruction:** Deleting, formatting, and overwriting (not foolproof).
- **Sanitization:** Makes data recovery infeasible.
- **Purge:** Renders data irrecoverable even in labs.
- **Degaussing:** Destroys magnetic media with a strong magnetic field.
- **Physical Destruction:** Disk crushing, shredding, incineration, etc. Often used alongside soft methods.

Information Life Cycle:

- **Data Acquisition:** Creation or copying, indexing, and storage.
- **Data Use:** Ensure confidentiality, integrity, and availability (CIA Triad).
- **Data Archival:** Store as required by law or for future use. Differentiate from backups.
- **Data Disposal:** Properly dispose of data when no longer needed.

Administrative (Directive) Controls

Access Control Categories:

- **Administrative Controls:** Policies and procedures.
- **Technical Controls:** Firewalls, routers, encryption.
- **Physical Controls:** Locks, fences, guards.

Access Control Types:

- **Preventative:** Stop actions before they occur.
- **Detective:** Identify actions during or after an event.
- **Corrective:** Fix issues following an event.
- **Recovery:** Assist in recovery post-event.
- **Deterrent:** Discourage actions.
- **Compensating:** Provide alternatives when primary controls fail.

Policies:

- **Acceptable Use Policy (AUP):** Defines acceptable network/resource use.
- **BYOD Policy:** Guidelines for personal device use.
- **Privacy Policy:** Details on data collection, use, and management.

Password Policy:

- Retain last 24 passwords.
- **Maximum age:** 90 days; Minimum age: 2 days.
- **Minimum length:** 8 characters; Complexity requirements.

Data Handling Policy: Classify, label, encrypt, store, backup, dispose.

3 States of Data:

- **Data at Rest:** Stored data.
- **Data in Motion:** Data being transferred.
- **Data in Use:** Actively used data, typically unencrypted.

Training and Awareness

Users as a Security Risk:

- **Training:** Equips users with security skills.
- **Awareness:** Aims to change user behavior to enhance security.
- **Goal:** Cultivate a cybersecurity culture with strong cyber hygiene practices.

Social Engineering

Social Engineering: Uses psychological manipulation to bypass security controls, often easier than technical attacks.

Common Tactics:

- **Authority:** Impersonate a trusted figure.
- **Intimidation:** Threaten negative consequences.
- **Consensus:** Leverage social proof or fake reviews.
- **Scarcity:** Create urgency with limited availability.
- **Urgency:** Imply immediate action is needed.
- **Familiarity:** Build rapport or common ground with the target.

Attack Types:

- **Phishing:** Mass email scams seeking sensitive info.
- **Spear Phishing:** Targeted phishing using specific details about the victim.
- **Whale Phishing (Whaling):** Targets high-profile individuals within an organization.
- **Vishing:** Voice-based phishing using automated calls.
- **Example:** Successful attacks may involve tactics like free giveaways to lure targets.